FOR ORGANIZATIONS USING AI GATEWAYS

FraudGuard

A behavior-change monitor for a company's own AI use across teams and providers.

This proposal is for any organization that routes AI requests through Bifrost or another gateway with a compatible integration. The aim is to help the company notice unusual changes in how its own apps and teams use AI—not to monitor the provider's other customers.

Company apps / teams
↓
Company gateway + FraudGuard
↓
One or more AI providers

What it does: observes request patterns and reports explainable signals for a person to review. It does not block, authorize, or change requests.

Important boundary: requests sent directly from an app to a provider bypass a gateway plugin. Those calls need to be routed through the gateway or covered by a separate, approved integration.

The current code is a Bifrost companion prototype. A different gateway needs a compatibility assessment; support for every provider or gateway is not claimed.

TWO CREDENTIALS, TWO JOBS

One upstream key can serve many internal keys

Provider credential: the gateway uses it to authenticate to an AI provider. It stays in the gateway's secret manager.

Company virtual key: the company gives these to its apps, teams, or services so the gateway can identify who is using AI.

One provider credential can back requests from multiple company virtual keys. The keys are different credentials and must not be copied into each other's role.

Why separate internal keys? If every app uses one shared company key, the gateway may not be able to distinguish one app's behavior from another's.

Never expose secrets: do not put provider or virtual-key secrets in findings, dashboards, PDFs, email, or source control. Use internal IDs or carefully designed pseudonymous references.

FraudGuard's Bifrost adapter uses the resolved internal virtual-key ID when available—not the raw bearer-key value. Requests without that identity are passed through but are not profiled.

BE CLEAR ABOUT WHAT EXISTS

Prototype today; dashboard later

In the current prototype

- Observe-only request hooks for Bifrost.
- Behavior signals for model/provider changes, request timing, token-volume changes, and failures that reach the hook.
- Bounded per-process memory; no raw prompts or raw keys in findings.
- Structured findings/callback and aggregate metrics.

Not included yet

- No customer dashboard or durable/shared database.
- No production billing meter.
- Findings omit key identifiers, so per-key dashboard views need a safe pseudonymous reference.
- Memory resets on restart; replicas do not share baselines.

Dashboard option: send sanitized findings to a company-controlled store, then show trends and alert reasons with access controls and retention rules. Start with aggregate views; add pseudonymous per-key views only after privacy review.

A dashboard is a proposed product component, not a feature already delivered by this plugin.

DISCOVERY THROUGH SANDBOX SETUP

Start with the customer's request path

1 · Discovery and fit
Map apps, teams, providers, gateways, authentication, existing controls, and direct-to-provider traffic. Confirm whether requests can use a distinct virtual key per app/team.

2 · Scope and privacy
Choose pilot users, signals, retention, dashboard audience, success measures, owners, and data handling. Separate provider credentials from customer virtual keys.

3 · Prepare a non-production environment
Confirm gateway version and plugin path, access approvals, test identities, logging destination, rollback owner, and a restricted provider sandbox credential—or synthetic tests only.

Entry gate: do not start the schedule until the customer approves access, names technical/security contacts, and agrees on test cases and data rules.

Any timeline is an estimate until gateway compatibility, access, security review, and provider test credentials are confirmed.

INTEGRATION THROUGH HANDOVER

Build, test, then decide

4 · Integrate in the gateway
Install the compatible plugin in a non-production gateway. Forward only sanitized findings to an approved sink; keep requests observe-only.

5 · Test and tune
Run normal and synthetic anomaly cases, verify privacy and failure behavior, review false alerts, and measure latency/resource use. Do not enable automatic blocking.

6 · Review and hand over
Deliver evidence, limitations, configuration notes, support ownership, monitoring and rollback instructions, and a production go/no-go decision.

Possible first pilot: 30 business days after access and approvals, divided into discovery/setup, integration, testing, and handover. Delayed dependencies pause the clock.

Production gate: no rollout until the customer accepts compatibility, privacy, measured performance, alert quality, persistence/replica design, dashboard ownership, and support responsibilities.

EVIDENCE BEFORE PRODUCTION

What the test plan must prove

Detection and quality

- Benign baseline and warmup behave as expected.
- Model/provider probing, rapid sequences, token spikes, and repeated errors produce explainable findings.
- Review false positives using the customer's approved synthetic or test traffic.

Safety and reliability

- Requests are not blocked or modified, including when scoring or reporting fails.
- Concurrency, state expiry, restarts, and memory bounds are checked.
- No prompts, raw keys, provider credentials, or sensitive error text appear in findings.
- Measure latency and resource use on the agreed gateway setup.

Acceptance evidence: test results, observed false-alert rate, privacy check, measured latency, supported gateway/version, known gaps, and named customer approver.

Payment velocity, location, and expired/revoked/exposed-key signals require trusted data from the host. They are not automatically discovered by the LLM request hook.

RESPONSIBILITIES AND LIMITS

One installation can cover many keys

A possible subscription unit is the number of distinct protected company virtual keys active in a billing month—not the number of physical deployments. Any example price, including $1 per key per month, is an unvalidated hypothesis until buyers confirm it.

Customer owns: gateway/provider account, provider charges, staff access, source-of-truth key mapping, secret manager, and approval of any production deployment.

Product operator owns: plugin maintenance, supported-version list, privacy-safe event handling, dashboard security if built, incident response, and customer support.

Known limits: the plugin is a Bifrost companion module, not built into upstream Bifrost; current state is local/in-memory; no dashboard or billing meter exists; no gateway other than the tested contract is promised.

Bifrost contract reference: inspected source commit. Replit, if used for a demo, is optional test hosting—not the customer's production gateway or an endorsement.

This document is a study and proposed work plan. It does not claim a customer, provider integration, upstream acceptance, production readiness, or guaranteed savings/profit.